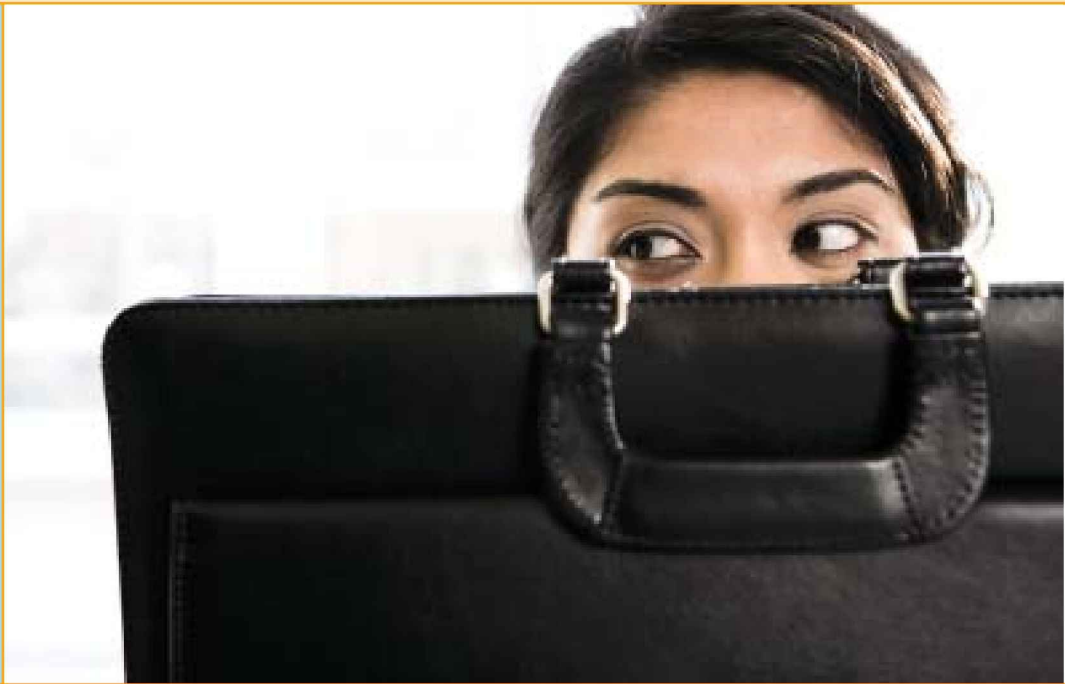


chapter 4

The Role of People in Security

Even in the common affairs of life, in love, friendship, and marriage, how little security have we when we trust our happiness in the hands of others!

—WILLIAM HAZLITT



In this chapter, you will learn how to

- Define basic terminology associated with social engineering
- Describe steps organizations can take to improve their security
- Describe common user actions that may put an organization's information at risk
- Recognize methods attackers may use to gain information about an organization
- Determine ways in which users can aid instead of detract from security

The operational model of computer security discussed in the previous chapter acknowledges that absolute protection of computer systems and networks is not possible and that we need to be prepared to detect and respond to attacks that were able to circumvent our security mechanisms. Another very basic fact that should be recognized is that technology alone will not solve the security problem. No matter how advanced the technology is, it will ultimately be deployed in an environment where humans exist. It is the human element that poses the biggest security challenge. It is hard to compensate for all of the possible ways that humans can deliberately or accidentally cause security problems or circumvent our security mechanisms. Despite all of the technology, despite all of the security procedures we have in place, and despite all of the security training we may provide, somebody will invariably fail to do what they are supposed to do, or do something they are not supposed to do, and create a vulnerability in the organization's security posture. This chapter discusses the human element and the role that people play in security—both the user practices that can aid in securing an organization and the vulnerabilities or holes in security that users can introduce.

■ People—A Security Problem

The operational model of computer security acknowledges that prevention technologies are not sufficient to protect our computer systems and networks. There are a number of explanations for why this is true, some of them technical, but one of the biggest reasons that prevention technologies are not sufficient is that every network and computer system has at least one human user, and humans are prone to make mistakes and are often easily misled or fooled.

Social Engineering

Social engineering, if you recall from Chapter 2, is the process of convincing an authorized individual to provide confidential information or access to an unauthorized individual. It is a technique in which the attacker uses various deceptive practices to convince the targeted person to divulge information they normally would not divulge or to convince the target of the attack to do something they normally wouldn't do. Social engineering is very successful for two general reasons. The first is the basic desire of most people to be helpful. When somebody asks a question for which we know the answer, our normal response is not to be suspicious but rather to answer the question. The problem with this is that seemingly innocuous information can be used either directly in an attack or indirectly to build a bigger picture that an attacker can use to create an aura of authenticity during an attack—the more information an individual has about an organization, the easier it will be to convince others that he is part of the organization and has a right to even sensitive information. An attacker who is attempting to exploit the natural tendency of people to be helpful may take one of several approaches:

- The attacker may simply ask a question, hoping to immediately obtain the desired information. For basic information that is not considered sensitive, this approach generally works. As an example, an attacker might call and ask who the IT manager is.
- The attacker may first attempt to engage the target in conversation and try to evoke sympathy so that the target feels sorry for the individual and is more prone to provide the information. For information that is even slightly sensitive in nature, the request of which could possibly arouse suspicion, this technique may be tried. As an example, an attacker might call and claim to be under some deadline from a supervisor who is upset for some reason. The target, feeling sorry for an alleged fellow worker, may give up the information, thinking they are helping them avoid trouble with the supervisor.
- The attacker may appeal to an individual's ego. As an example, an attacker might call the IT department, claiming to have some sort of problem, and praising them for work they supposedly did to help another worker. After being told how great they are and how much they helped somebody else, they will often be tempted to demonstrate that they can supply the same level of help to another individual. This technique may be used to obtain sensitive information, such as having the target's password reset.

The second reason that social engineering is successful is that individuals normally seek to avoid confrontation and trouble. If the attacker attempts to intimidate the target, threatening to call the target's supervisor because of a lack of help, the target may give in and provide the information to avoid confrontation. This variation on the attack is often successful in organizations that have a strict hierarchical structure. In the military, for example, a lower-ranking individual may be coerced into providing information to an individual claiming to be of higher rank or to be working for another individual higher up in the chain of command.

Social engineering may also be accomplished using other means besides direct contact between the target and the attacker. For example, an attacker might send a forged e-mail with a link to a bogus web site that has been set up to obtain information from or convince an individual to perform some action. Again, the goal in social engineering is to convince the target to provide information that they normally wouldn't divulge or perform some act that they normally would not do. An example of a slightly different attack

that is generally still considered a social engineering attack is one in which an attacker replaces the blank deposit slips in a bank's lobby with ones containing his or her own account number but no name. When an unsuspecting customer uses one of the slips, a teller who is not observant may end up crediting the attacker's account with the deposit.



Cross Check

Social Engineering

Chapters 1 and 2 both discussed social engineering. Electronic versions of social engineering have become very common. What are the different types of social engineering (especially electronic versions) that we have discussed?



Up to this point, social engineering has been discussed in the context of an outsider attempting to gain information about the organization. This does not have to be the case. Insiders may also attempt to gain information they are not authorized to have. In many cases, the insider may be much more successful since they will already have a certain level of information regarding the organization and can therefore better spin a story that may be believable to other employees.

Obtaining Insider Information

An excellent example of social engineering occurred in 1978 when Stanley Mark Rifkin, from Carlsbad, California, stole \$10.2 million from the Security Pacific Bank in Los Angeles. Details of the story vary, as Rifkin has never publicly detailed his actions, but a number of facts are known. At the time of the attack, Rifkin was working as a computer consultant for the bank. While working there, he learned details on how money could easily be transferred to accounts anywhere in the United States. The problem would be to actually obtain the money in the first place. In order to do this, he needed to have access to the electronic funds transfer (EFT) code used by the bank to transfer money to other banks. Using the excuse of checking on the computer equipment inside of the room from which the bank made its transfers, Rifkin was able to observe the code for that day. After leaving the room, he used this information to impersonate a bank officer and ordered the transfer of the \$10.2 million. Since he had knowledge of the supposedly secret code, the transfer was made with little fanfare (this amount was well below any level that would trigger any suspicion). Earlier Rifkin had set up a bogus account in a New York bank, using a false name, and he deposited the money into that account. He later transferred the money again to another account in Switzerland under a different name. He then used the money to purchase millions of dollars in diamonds, which he then smuggled back into the United States. The crime might have gone undetected if he had not boasted

of his exploits to an individual who was more than happy to turn him in. In 1979, Rifkin was sentenced to eight years in prison. At his trial he attempted to convince the judge that he should be released so he could teach others how to protect their systems against the type of activity he perpetrated. The judge denied this request. The diamonds were ultimately turned over to the bank, which tried to recover its loss by selling them.

Phishing

Phishing (pronounced “fishing”) is a type of social engineering in which an attacker attempts to obtain sensitive information from a user by masquerading as a trusted entity in an e-mail or instant message sent to a large group of often random users. The attacker attempts to obtain information such as usernames, passwords, credit card numbers, and details about the user’s bank accounts. The message sent often encourages the user to go to a web site that appears to be for a reputable entity such as PayPal or eBay, both of which have frequently been used in phishing attempts. The web site the user actually visits is not owned by the reputable organization, however, and asks the user to supply information that can be used in a later attack. Often the message sent to the user will state that the user’s account has been compromised and will request, for security purposes, the user to enter their account information to verify the details.

In another very common example of phishing, the attacker sends a bulk e-mail, supposedly from a bank, telling the recipients that a security breach has occurred and instructing them to click a link to verify that their account has not been tampered with. If the individual actually clicks the link, they are taken to a site that appears to be owned by the bank but is actually controlled by the attacker. When they supply their account and password for “verification” purposes, they are actually giving it to the attacker.

The e-mails and web sites generated by the attackers often appear to be legitimate. A few clues, however, can tip off the user that the e-mail might not be what it claims to be. The e-mail may contain grammatical and typographical errors, for example. Organizations that are used in these phishing attempts (such as eBay and PayPal) are careful about their images and will not send a security-related e-mail to users containing obvious errors. In addition, almost unanimously, organizations tell their users that they will never ask for sensitive information (such as a password or account number) via an e-mail. The URL of the web site that the users are taken to may also provide a clue that the site is not what it appears to be. Despite the increasing media coverage concerning phishing attempts, some Internet users still fall for them, which results in attackers continuing to use this relatively cheap method to gain the information they are seeking.

A recent development has been the introduction of a modification to the original phishing attack. *Spear phishing* is the term that has been created to refer to the special targeting of groups with something in common when launching a phishing attack. By targeting specific groups, the ratio of successful attacks (that is, the number of responses received) to the total number of e-mails or messages sent usually increases because a targeted attack will seem more plausible than a message sent to users randomly.

Pharming consists of misdirecting users to fake web sites made to look official. Using phishing, individuals are targeted one by one by sending out e-mails. To become a victim, the recipients must take an action themselves



Exam Tip: Phishing is now the most common form of social engineering attack related to computer security. The target may be a computer system and access to the information found on it (such as is the case when the phishing attempt asks for a user ID and password) or the target may be personal information, generally financial, about an individual (in the case of phishing attempts that ask for an individual’s banking information).



Another specialized version of phishing is closely related to spear phishing. Again specific individuals are targeted, but in this case, the individuals are important individuals high up in an organization such as the corporate officers. The goal is to go after these “bigger targets,” and thus the term that is used to refer to this form of attack is *whaling*.

(for example, respond by providing personal information). In pharming, the user will be directed to the fake web site as a result of activity such as DNS poisoning (an attack that changes URLs in a server's domain name table) or modification of local host files, which are used to convert URLs to the appropriate IP address. Once at the fake site, the user may supply personal information, believing that they are connected to the legitimate site.

Vishing

Vishing is a variation of phishing that uses voice communication technology to obtain the information the attacker is seeking. Vishing takes advantage of the trust that some people place in the telephone network. Users are unaware that attackers can spoof (simulate) calls from legitimate entities using voice over IP (VoIP) technology. Voice messaging can also be compromised and used in these attempts. Generally, the attackers are hoping to obtain credit card numbers or other information that can be used in identity theft. The user may receive an e-mail asking him or her to call a number that is answered by a potentially compromised voice message system. Users may also receive a recorded message that appears to come from a legitimate entity. In both cases, the user will be encouraged to respond quickly and provide the sensitive information so that access to their account is not blocked. If a user ever receives a message that claims to be from a reputable entity and asks for sensitive information, the user should not provide it but instead should use the Internet or examine a legitimate account statement to find a phone number that can be used to contact the entity. The user can then verify that the message received was legitimate or report the vishing attempt.



Tech Tip

Beware of Vishing

Vishing (phishing conducted using voice systems) is generally successful because of the trust that individuals place in the telephone system. With caller ID, people believe they can identify who it is that is calling them. They do not understand that, just like many protocols in the TCP/IP protocol suite, caller ID can be spoofed.

SPAM

Though not generally considered a social engineering issue, nor a security issue for that matter, **SPAM** can, however, be a security concern. SPAM, as just about everybody knows, is bulk unsolicited e-mail. It can be legitimate in the sense that it has been sent by a company advertising a product or service, but it can also be malicious and could include an attachment that contains malicious software designed to harm your system, or a link to a malicious web site that may attempt to obtain personal information from you. Though not as well known, a variation on SPAM is *SPIM*, which is basically SPAM delivered via an instant messaging application such as Yahoo! Messenger or AIM. The purpose of hostile SPIM is the same as that of SPAM—the delivery of malicious content or links.

Shoulder Surfing

Shoulder surfing does not necessarily involve direct contact with the target, but instead involves the attacker directly observing the individual entering sensitive information on a form, keypad, or keyboard. The attacker may simply look over the shoulder of the user at work, for example, or may set up a camera or use binoculars to view the user entering sensitive data. The attacker can attempt to obtain information such as a personal identification number (PIN) at an automated teller machine (ATM), an access control entry code at a secure gate or door, or a calling card or credit card number. Many locations now use a small shield to surround a keypad so that it is difficult to observe somebody entering information. More sophisticated



A related, somewhat obvious security precaution is that a person should not use the same PIN for all of their different accounts, gate codes, and so on, since an attacker who learns the PIN for one type of access could then use it for all of the other types of access.

systems can actually scramble the location of the numbers so that the top row at one time includes the numbers 1, 2, and 3 and the next time 4, 8, and 0. While this makes it a bit slower for the user to enter information, it thwarts an attacker's attempt to observe what numbers are pressed and enter the same buttons/pattern, since the location of the numbers constantly changes.

Although methods such as adding shields to block the view or having the pad "scramble" the numbers can help make shoulder surfing more difficult, the best defense is for users to be aware of their surroundings and to not allow individuals to get into a position from which they can observe what the user is entering.

The attacker may attempt to increase the chance of successfully observing the target entering the data by starting a conversation with the target. This provides an excuse for the attacker to be physically closer to the target. Otherwise, the target may be suspicious if the attacker is standing too close. In this sense, shoulder surfing can be considered a social engineering attack.

Reverse Social Engineering

A slightly different approach to social engineering is called **reverse social engineering**. In this technique, the attacker hopes to convince the target to initiate the contact. This obviously differs from the traditional approach, where the target is the one that is contacted. The reason this attack may be successful is that, since the target is the one initiating the contact, attackers may not have to convince the target of their authenticity. The tricky part of this attack is, of course, convincing the target to make that initial contact. Possible methods to accomplish this might include sending out a spoofed e-mail (fake e-mail designed to appear authentic) that claims to be from a reputable source and provides another e-mail address or phone number to call for "tech support," or posting a notice or creating a bogus web site for a legitimate company that also claims to provide "tech support." This may be especially successful if timed to coincide with a company's deployment of a new software or hardware platform. Another potential time to target an organization with this sort of attack is when there is a significant change in the organization itself, such as when two companies merge or a smaller company is acquired by a larger one. During these times, employees are not familiar with the new organization or its procedures, and amidst the confusion, it is easy to conduct either a social engineering or reverse social engineering attack.

Hoaxes

At first glance, it might seem that a hoax related to security would be considered a nuisance and not a real security issue. This might be the case for some hoaxes, especially those of the urban legend type, but the reality of the situation is that a hoax can be very damaging if it causes users to take some sort of action that weakens security. One real hoax, for example, described a new, highly destructive piece of malicious software. It instructed users to check for the existence of a certain file and to delete it if the file was found. In reality, the file mentioned was an important file used by the operating system, and deleting it caused problems the next time the system was booted. The damage caused by users modifying security settings can be serious. As with other forms of social engineering, *training and awareness* are the best and first



Tech Tip

Be Aware of Reverse Social Engineering

Reverse social engineering is not nearly as widely understood as social engineering and is a bit trickier to execute. If the attacker is successful in convincing an individual to make the initial contact, however, the process of convincing them of the authenticity of the attacker is generally much easier than in a social engineering attack.

line of defense for both users and administrators. Users should be trained to be suspicious of unusual e-mails and stories and should know who to contact in the organization to verify their validity if they are received. Hoaxes often also advise the user to send it to their friends so they know about the issue as well—and by doing so, they help spread the hoax. Users need to be suspicious of any e-mail telling them to “spread the word.”

Poor Security Practices

A significant portion of human-created security problems results from poor security practices. These poor practices may be those of an individual user who is not following established security policies or processes, or they may be caused by a lack of security policies, procedures, or training within the user’s organization.



Poor password selection is one of the most common of poor security practices, and one of the most dangerous. Numerous studies that have been conducted on password selection have found that, while overall more users are learning to select good passwords, a significant percentage of users still make poor choices. The problem with this, of course, is that a poor password choice can enable an attacker to compromise a computer system or network more easily. Even when users have good passwords, they often resort to another poor security practice—writing the password down in an easily located place, which can also lead to system compromise if an attacker gains physical access to the area.

Password Selection

For many years, computer intruders have relied on users selecting poor passwords to help them gain unauthorized access to a system or network. If attackers could obtain a list of the users’ names, chances were good they could eventually access the system. Users tend to pick passwords that are easy for them to remember, and what easier password could there be than the same sequence of characters that they use for their user ID? If a system has an account with the username *jdoe*, an attacker’s reasonable first guess of the account’s password would be *jdoe*. If this doesn’t work, the attacker would try variations on the same, such as *doej*, *johndoe*, *johnd*, and *eodj*, all of which would be reasonable possibilities.

If the attacker’s attempt to use variations on the username does not yield the correct password, they might simply need more information. Users also frequently pick names of family members, pets, or favorite sports team. If the user lives in San Antonio, Texas, for example, a possible password might be *gospursgo* in honor of their professional basketball team. If these don’t work for the attacker, then the attacker might next try hobbies of the user, the name of their favorite make or model of car, or similar pieces of information. The key is that the user often picks something easy for them to remember, which means that the more you know about the user, the better your chance of discovering their password.

In an attempt to complicate the attacker’s job, organizations have encouraged their users to mix upper- and lowercase characters and to include numbers and special characters in their password. While this does make the password harder to guess, the basic problem still remains: users will pick something that is easy for them to remember. Thus, our user in San Antonio may select the password *G0*Spurs*G0*, capitalizing three of the letters, inserting a special character twice, and substituting the number zero for the letter O. This makes the password harder to crack, but there are a finite number of variations on the basic *gospursgo* password, so, while the attacker’s job has been made more difficult, it is still possible to guess the password.

Organizations have also instituted additional policies and rules relating to password selection to further complicate an attacker’s efforts. Organizations, for example, may require users to frequently change their password. This means that if an attacker is able to guess a password, it is only valid for

a limited period of time before a new password is selected, after which the attacker is locked out. All is not lost for the attacker, however, since, again, users will select passwords they can remember. For example, password changes often result in a new password that simply incorporates a number at the end of the old one. Thus, our San Antonio user might select *G0*Spurs*G1* as the new password, in which case the benefit of forcing password changes on a periodic, or even frequent, basis has been totally lost. It is a good bet that the next password chosen will be *G0*Spurs*G2*, followed by *G0Spurs*G3*, and so forth.

Another policy or rule governing password selection often adopted by organizations is that passwords must not be written down. This, of course, is difficult to enforce, and thus users will frequently write them down, often as a result of what we refer to as the “password dilemma.” The more difficult we make it for attackers to guess our passwords, and the more frequently we force password changes, the more difficult the passwords are for authorized users to remember and the more likely they are to write them down. Writing them down and putting them in a secure place is one thing, but all too often users will write them on a slip of paper and keep them in their calendar, wallet, or purse. Most security consultants generally agree that if they are given physical access to an office, they will be able to find a password somewhere—the top drawer of a desk, inside of a desk calendar, attached to the underside of the keyboard, or even simply on a yellow “sticky note” attached to the monitor.

With the proliferation of computers, networks, and users, the password dilemma has gotten worse. Today, the average Internet user probably has at least a half dozen different accounts and passwords to remember. Selecting a different password for each account, following the guidelines mentioned previously regarding character selection and frequency of changes, only aggravates the problem of remembering the passwords. This results in users all too frequently using the same password for all accounts. If a user does this, and then one of the accounts is broken, all other accounts are subsequently also vulnerable to attack.

As a final comment, good password selection and the protection of passwords also applies to another common feature of today’s electronic world, PINs. Most people have at least one PIN associated with things such as their ATM card or a security code to gain physical access to a room. Again, users will invariably select numbers that are easy to remember. Specific numbers, such as the individual’s birth date, their spouse’s birth date, or the date of some other significant event, are all common numbers to select. Other people will pick patterns that are easy to remember—2580, for example, uses all of the center numbers on a standard numeric pad on a telephone. Attackers know this, and guessing PINs follows the same sort of process that guessing a password does.

Password selection is an individual activity, and to ensure that individuals are making good selections is the realm of the entity’s password policy. To ensure users make appropriate choices, they need to be aware of the issue and their personal role in securing accounts. An effective password policy conveys both the user role and responsibility associated with password usage and does so in a simple enough manner that it can be conveyed via screen notes during mandated password change events.



Exam Tip: Know the rules for good password selection. Generally, these are to use eight or more characters in your password, include a combination of upper- and lowercase letters, include at least one number and one special character, do not use a common word, phrase, or name, and choose a password that you can remember so that you do not need to write it down.

Piggybacking

People are often in a hurry and will frequently not follow good physical security practices and procedures. Attackers know this and may attempt to exploit this characteristic in human behavior. **Tailgating** or **piggybacking** is the simple tactic of following closely behind a person who has just used their own access card or PIN to gain physical access to a room or building. An attacker can thus gain access to the facility without having to know the access code or having to acquire an access card. It is similar to shoulder surfing in that it relies on the attacker taking advantage of an authorized user not following security procedures. Frequently the attacker may even start a conversation with the target before reaching the door so that the user may be more comfortable with allowing the individual in without challenging them. In this sense piggybacking is related to social engineering attacks. Both the piggybacking and shoulder surfing attack techniques can be easily countered by using simple procedures to ensure nobody follows you too closely or is in a position to observe your actions. Both of these rely on the poor security practices of an authorized user in order to be successful. A more sophisticated countermeasure to piggybacking is a “man trap,” which utilizes two doors to gain access to the facility. The second door does not open until the first one is closed and is spaced close enough to the first that an enclosure is formed that only allows one individual through at a time.

Dumpster Diving

As mentioned earlier, attackers need a certain amount of information before launching their attack. One common place to find this information, if the attacker is in the vicinity of the target, is the target’s trash. The attacker might find little bits of information that could be useful for an attack. This process of going through a target’s trash in hopes of finding valuable information that might be used in a penetration attempt is known in the computer community as **dumpster diving**. The tactic is not, however, unique to the computer community; it has been used for many years by others, such as identity thieves, private investigators, and law enforcement personnel, to obtain information about an individual or organization. If the attackers are very lucky, and the target’s security procedures are very poor, they may actually

find user IDs and passwords. As mentioned in the discussion on passwords, users sometimes write their password down. If, when the password is changed, they discard the paper the old password was written on without shredding it, the lucky dumpster diver can gain a valuable clue. Even if the attacker isn’t lucky enough to obtain a password directly, he undoubtedly will find employee names, from which it’s not hard to determine user IDs, as discussed earlier. Manuals from hardware or software that have



Try This

Dumpster Diving

The amount of useful information that users throw away in unsecured trash receptacles often amazes security professionals. Hackers know that they can often find manuals, network diagrams, and even user IDs and passwords by rummaging through dumpsters. After coordinating this with your security office, try seeing what you can find that individuals in your organization have discarded (assuming that there is no shredding policy) by either going through your organization’s dumpsters or just through the office trash receptacles. What useful information did you find? Is there an obvious suggestion that you might make to enhance the security of your organization?

been purchased may also provide clues as to what vulnerabilities exist on the target's computer systems and networks. Finally, the attacker may gather a variety of information that can be useful in a social engineering attack. In most locations, trash is no longer considered private property after it has been discarded (and even where dumpster diving is illegal, little enforcement occurs). An organization should have policies about discarding materials. Sensitive information should be shredded and the organization should consider securing the trash receptacle so that individuals can't forage through it. People should also consider shredding personal or sensitive information that they wish to discard in their own trash. A reasonable quality shredder is inexpensive and well worth the price when compared with the potential loss that could occur as a result of identity theft.

Installing Unauthorized Hardware and Software

Organizations should have a policy that restricts the ability of normal users to install software and new hardware on their systems. A common example is a user installing unauthorized communication software and a modem to allow them to connect to their machine at work via a modem from their home. Another common example is a user installing a wireless access point so that they can access the organization's network from many different areas. In these examples, the user has set up a backdoor into the network, circumventing all the other security mechanisms in place. The term "rogue modem" or "rogue access point" may be used to describe these two cases. A **backdoor** is an avenue that can be used to access a system while circumventing normal security mechanisms and can often be used to install additional executable files that can lead to more ways to access the compromised system. Security professionals can use widely available tools to scan their own systems periodically for either of these rogue devices to ensure that users haven't created a backdoor.

Another common example of unauthorized software that users install on their systems is games. Unfortunately, not all games come in shrink-wrapped packages. Numerous small games can be downloaded from the Internet. The problem with this is that users don't always know where the software originally came from and what may be hidden inside it. Many individuals have unwittingly installed what seemed to be an innocuous game, only to have downloaded a piece of malicious code capable of many things, including opening a backdoor that allows attackers to connect to, and control, the system from across the Internet.

Because of these potential hazards, many organizations do not allow their users to load software or install new hardware without the knowledge and assistance of administrators. Many organizations also screen, and occasionally intercept, e-mail messages with links or attachments that are sent to users. This helps prevent users from, say, unwittingly executing a hostile program that was sent as part of a worm or virus. Consequently, many organizations have their mail servers strip off executable attachments to e-mail so that users can't accidentally cause a security problem.

Physical Access by Non-Employees

As has been mentioned, if an attacker can gain physical access to a facility, chances are very good that the attacker can obtain enough information to



It has already been mentioned that gaining physical access to a computer system or network often guarantees an attacker success in penetrating the system or the network it is connected to. At the same time, there may be a number of individuals who have access to a facility but are not authorized to access the information the systems store and process. We become complacent to the access these individuals have because they often quietly go about their job so as to not draw attention to themselves and to minimize the impact on the operation of the organization. They may also be overlooked because their job does not impact the core function of the organization. A prime example of this is the custodial staff. Becoming complacent about these individuals and not paying attention to what they may have access to, however, could be a big mistake, and users should not believe that everybody who has physical access to the organization has the same level of concern for or interest in the welfare of the organization.

penetrate computer systems and networks. Many organizations require employees to wear identification badges when at work. This is an easy method to quickly spot who has permission to have physical access to the organization and who does not. While this method is easy to implement and can be a significant deterrent to unauthorized individuals, it also requires that employees actively challenge individuals who are not wearing the required identification badge. This is one area where organizations fail. Combine an attacker who slips in by piggybacking off of an authorized individual and an environment where employees have not been encouraged to challenge individuals without appropriate credentials and you have a situation where you might as well not have any badges in the first place. Organizations also frequently become complacent when faced with what appears to be a legitimate reason to access the facility, such as when an individual shows up with a warm pizza claiming it was ordered by an employee. It has often been stated by security consultants that it is amazing what you can obtain access to with a pizza box or a vase of flowers. If the organization doesn't enforce good password policies, a casual stroll through an office may yield passwords or other important information.



Preventing access to information is also important in the work area. Firms with sensitive information should have a "clean desk policy" specifying that sensitive information is not left unsecured in the work area when the worker is not present to act as custodian.

Another aspect that must be considered is personnel who have legitimate access to a facility but also have intent to steal intellectual property or otherwise exploit the organization. Physical access provides an easy opportunity for individuals to look for the occasional piece of critical information carelessly left out. With the proliferation of devices such as cell phones with built-in cameras, an individual could easily photograph information without it being obvious to employees. Contractors, consultants, and partners frequently not only have physical access to the facility but may also have network access. Other individuals who typically have unrestricted access to the facility when no one is around are nighttime custodial crewmembers and security guards. Such positions are often contracted out. As a result, hackers have been known to take temporary custodial jobs simply to gain access to facilities.

■ People as a Security Tool

An interesting paradox when speaking of social engineering attacks is that people are not only the biggest problem and security risk but also the best tool in defending against a social engineering attack. The first step a company should take to fight potential social engineering attacks is to create the policies and procedures that establish the roles and responsibilities for not only security administrators but for all users. What is it that management expects, security-wise, from all employees? What is it that the organization is trying to protect, and what mechanisms are important for that protection?

Security Awareness

Probably the single most effective method to counter potential social engineering attacks, after establishment of the organization's security goals and policies, is an active security awareness program. The extent of the training will vary depending on the organization's environment and the level of threat, but initial employee training on social engineering at the time a

person is hired is important, as well as periodic refresher training. Many government organizations have created security awareness posters to constantly remind individuals of this possible avenue of attack. Security newsletters, often in the form of e-mail, have also been used to remind employees of their security responsibilities.

An important element that should be stressed in training about social engineering is the type of information that the organization considers sensitive and which may be the target of a social engineering attack. There are undoubtedly signs that the organization could point to as indicative of an attacker attempting to gain access to sensitive corporate information. All employees should be aware of these indicators. The scope of information that an attacker may ask for is very large, and many questions attackers pose might also be legitimate in another context (asking for the phone number for somebody, for example). Employees should be taught to be cautious about revealing personal information and should especially be alert for questions regarding account information, personally identifiable information, or passwords.



Try This

Security Awareness Programs

A strong security education and awareness training program can go a long way toward reducing the chance that a social engineering attack will be successful. Awareness programs and campaigns, which might include seminars, videos, posters, newsletters, and similar materials, are also fairly easy to implement and not very costly. There is no reason for an organization to not have an awareness program in place. A lot of information and ideas are available on the Internet. See what you can find that might be usable for your organization that you can obtain at no charge from various organizations on the Internet. (Tip: Check organizations such as NIST and NSA, which have developed numerous security documents and guidelines.)

Individual User Responsibilities

Individual user responsibilities vary between organizations and the type of business the organization is involved in, but there are certain very basic responsibilities that all users should be instructed to adopt:

- Lock the door to your office or workspace.
- Do not leave sensitive information inside your car unprotected.
- Secure storage media containing sensitive information in a secure storage device.
- Shred paper containing organizational information before discarding it.
- Do not divulge sensitive information to individuals (including other employees) who do not have an authorized need to know it.
- Do not discuss sensitive information with family members. (The most common violation of this rule occurs in regard to HR information, as employees, especially supervisors, may complain to their spouse about other employees or problems that are occurring at work.)
- Protect laptops that contain sensitive or important organization information wherever the laptop may be stored or left. (It's a good idea to ensure that sensitive information is encrypted on the laptop so that, should the equipment be lost or stolen, the information remains safe.)
- Be aware of who is around you when discussing sensitive corporate information. Does everybody within earshot have the need to hear this information?

- Enforce corporate access control procedures. Be alert to, and do not allow, piggybacking, shoulder surfing, or access without the proper credentials.
- Be aware of the correct procedures to report suspected or actual violations of security policies.
- Follow procedures established to enforce good password security practices. Passwords are such a critical element that they are frequently the ultimate target of a social engineering attack. Though such password procedures may seem too oppressive or strict, they are often the best line of defense.

As a final note on user responsibilities, corporate security officers must cultivate an environment of trust in their office, as well as an understanding of the importance of security. If users feel that security personnel are only there to make their life difficult or dredge up information that will result in an employee's termination, the atmosphere will quickly turn adversarial and be transformed into an "us versus them" situation. Security personnel need the help of all users and should strive to cultivate a team environment in which users, when faced with a questionable situation, will not hesitate to call the security office. In situations like this, security offices should remember the old adage of "don't shoot the messenger."

Chapter 4 Review

■ Chapter Summary

After reading this chapter and completing the exercises, you should understand the following regarding the role people can play in security.

Define basic terminology associated with social engineering

- Social engineering is a technique in which the attacker uses various deceptive practices to convince the targeted person to divulge information they normally would not divulge, or to convince the target to do something they normally wouldn't do.
- In reverse social engineering, the attacker hopes to convince the target to initiate contact.

Describe steps organizations can take to improve their security

- Organizations should have a policy that restricts the ability of normal users to install new software and hardware on their systems.
- Contractors, consultants, and partners may frequently have not only physical access to the facility but also network access. Other groups that are given unrestricted, and unobserved, access to a facility are nighttime custodial crewmembers and security guards. Both are potential security problems and organizations should take steps to limit these individuals' access.
- The single most effective method to counter potential social engineering attacks, after establishing the organization's security goals and policies, is an active security awareness program.

Describe common user actions that may put an organization's information at risk

- No matter how advanced security technology is, it will ultimately be deployed in an environment where the human element may be its greatest weakness.
- Attackers know that employees are frequently very busy and don't stop to think about security. They may attempt to exploit this work characteristic through piggybacking or shoulder surfing.

Recognize methods attackers may use to gain information about an organization

- For many years computer intruders have relied on users selecting poor passwords to help them in their attempts to gain unauthorized access to a system or network.
- One common way to find useful information (if the attacker is in the vicinity of the target, such as a company office) is to go through the target's trash looking for bits of information that could be useful to a penetration attempt.

Determine ways in which users can aid instead of detract from security

- An interesting paradox of social engineering attacks is that people are not only the biggest problem and security risk, but also the best line of defense against a social engineering attack.
- A significant portion of employee-created security problems arise from poor security practices.
- Users should always be on the watch for attempts by individuals to gain information about the organization and should report suspicious activity to their employer.

■ Key Terms

backdoor (75)

dumpster diving (74)

phishing (69)

piggybacking (74)

reverse social engineering (71)

shoulder surfing (70)

social engineering (67)

SPAM (70)

tailgating (74)

vishing (70)

■ Key Terms Quiz

Use terms from the Key Terms list to complete the sentences that follow. Don't use the same term more than once. Not all terms will be used.

1. A _____ is an avenue that can be used to access a system while circumventing normal security mechanisms.
2. _____ is a procedure in which attackers position themselves in such a way as to be able to observe an authorized user entering the correct access code.
3. The process of going through a target's trash searching for information that can be used in an attack, or to gain knowledge about a system or network, is known as _____.
4. _____ is the simple tactic of following closely behind a person who has just used their access card or PIN to gain physical access to a room or building.
5. In _____, the attacker hopes to convince the target to initiate contact.

■ Multiple-Choice Quiz

1. Which of the following are considered good practices for password security?
 - A. Using a combination of upper- and lowercase characters, a number, and a special character in the password itself
 - B. Not writing the password down
 - C. Changing the password on a regular basis
 - D. All of the above
2. The password dilemma refers to the fact that:
 - A. Passwords that are easy for users to remember are also easy for attackers to guess.
 - B. The more difficult we make it for attackers to guess our passwords, and the more frequently we force password changes, the more difficult the passwords are for authorized users to remember and the more likely they are to write them down.
 - C. Users will invariably attempt to select passwords that are words they can remember. This means they may select things closely associated with them, such as their spouse's or child's name, a beloved sports team, or a favorite model of car.
 - D. Passwords assigned by administrators are usually better and more secure, but are often harder for users to remember.
3. The simple tactic of following closely behind a person who has just used their own access card or PIN to gain physical access to a room or building is called:
 - A. Shoulder surfing
 - B. Tagging-along
 - C. Piggybacking
 - D. Access drafting
4. The process of going through a target's trash in hopes of finding valuable information that might be used in a penetration attempt is known as:
 - A. Dumpster diving
 - B. Trash trolling
 - C. Garbage gathering
 - D. Refuse rolling
5. An avenue that can be used to access a system while circumventing normal security mechanisms is known as a:
 - A. Master-key code
 - B. Secret door
 - C. Backdoor
 - D. Covert channel
6. Reverse social engineering involves:
 - A. Contacting the target, eliciting some sensitive information, and convincing them that nothing out of the ordinary has occurred
 - B. Contacting the target in an attempt to obtain information that can be used in a second attempt with a different individual
 - C. An individual lower in the chain of command convincing somebody at a higher level to divulge information that the attacker is not authorized to have
 - D. An attacker attempting to somehow convince the target to initiate contact in order to avoid questions about authenticity

7. The reason for not allowing users to install new hardware or software without the knowledge of security administrators is:
 - A. They may not complete the installation correctly and the administrator will have to do more work, taking them away from more important security tasks.
 - B. They may inadvertently install more than just the hardware or software; they may accidentally install a backdoor into the network.
 - C. They may not have paid for it and thus may be opening the organization up to civil penalties.
 - D. Unauthorized hardware and software are usually for leisure purposes and will distract employees from the job they were hired to perform.
8. Once an organization's security policies have been established, the single most effective method of countering potential social engineering attacks is:
 - A. An active security awareness program
 - B. A separate physical access control mechanism for each department in the organization
 - C. Frequent testing of both the organization's physical security procedures and employee telephone practices
 - D. Implementing access control cards and the wearing of security identification badges
9. Security administrators should be concerned about security guards and custodial crews because:
 - A. These individuals may not have had a thorough background investigation.
 - B. These individuals have access to facilities at times when nobody else is around to view their activities.
 - C. These individuals are frequently paid minimal salaries.
 - D. These individuals are frequently contracted and are not actually employees of the company.
10. In what ways are PINs similar to passwords?
 - A. Users will normally pick a PIN that is easy to remember, such as a date or specific pattern.
 - B. Attackers know common PINs and will try to use them or will attempt to learn more about the user in order to make an educated guess as to what their PIN might be.
 - C. Users may write them down to remember them.
 - D. All of the above are true.

■ Essay Quiz

1. Explain the difference between social engineering and reverse social engineering.
2. Describe the process of piggybacking. Is this common attack technique possible in your work or school environment?
3. How might shoulder surfing be a threat in your school or work environment? What can be done to make this sort of activity more difficult?
4. For an environment familiar to you (such as work or school), describe the different non-employees who may have access to facilities that could contain sensitive information.
5. Describe some of the user security responsibilities that you feel are most important for users to remember.

Lab Projects

• Lab Project 4.1

If possible at either your place of employment or school, attempt to determine how easy it would be to perform dumpster diving in order to gain access to information

at the site. Are trash receptacles easy to gain access to? Are documents shredded before being discarded? Are areas where trash is stored easily accessible?

• Lab Project 4.2

Perform a search on the Web for articles and stories about social engineering attacks or reverse social engineering attacks. How many were successful?

How many failed and why? How could those that may have initially succeeded been prevented?